

面向政企场景的大模型智能体安全关键技术 研究

枢衡 Fulcrum 技术方案报告

题目编号：XA-202620

发榜单位：中国雄安集团数字城市科技有限公司

学生赛道 · 2026 年 8 月版

本文回答什么问题：如何在不修改基础模型的前提下，为政企智能体建立覆盖输入、工具、扩展组件、输出和审计的可验证安全控制层。

状态：定稿 v1.0（基于仓库当前实现与冻结评测记录；专项数据和后续增强明确标注）

摘要

政务办公、知识服务、流程办理和运维协同正在从问答式应用转向具备检索、记忆、工具调用与自动执行能力的智能体。风险边界随之从模型输出文本扩展到多源上下文、工具参数、扩展组件和运行过程。枢衡（Fulcrum）采用旁挂式安全网关，不改动被保护智能体，在模型调用和工具执行之间提供检测、来源归因、策略判定、分级处置、沙箱执行、供应链准入以及防篡改审计。

本方案将安全控制拆为四个相互衔接的目标：复杂输入链路攻击识别与风险评估；工具调用和任务执行的约束与审批；插件、Skill、脚本的供应链检测；安全评测与审计溯源。核心判定采用规则、小模型和可选本地 LLM Judge 的组合，工具层增加参数风险、来源污染和任务链分析，最终以 allow、sanitize、approve、block 四级处置落地。

主结果采用仓库冻结语料 v1.0.0 的 200 条样例回放：恶意 170 条、良性 30 条，当前 `latest.json` 记录 TP=152、FN=18、FP=0、TN=30，召回率 89.4%、精确率 100%、F1 94.4%、FPR 0%、正常任务可用性 100%；审计完整率和 hash-chain 校验通过率均为 100%。该结果是确定性管线在固定数据集上的工程基线，不等同于对所有模型、所有场景的安全保证。

关键词：政企智能体安全；提示注入；工具调用治理；来源归因；供应链安全；防篡改审计；可复现评测

1 项目背景与问题分析

1.1 赛题要求与建设边界

赛题要求提交技术方案报告、原型系统或核心算法代码、演示视频及可选评测材料，并重点考察技术创新性、实际效果、方案完整性、应用价值和展示表达。题目明确关注四类能力：复杂输入攻击识别、工具调用全流程安全约束、扩展组件供应链检测，以及评测与审计溯源。

本项目的建设边界是智能体外侧的安全控制层。它不替代基础模型，也不试图仅靠模型自觉完成安全；重点是在网络入口、工具调用点、执行环境和输出出口建立可观测、可配置、可阻断的强制点。

1.2 政企智能体的风险变化

- 多源输入污染：网页、附件、检索结果和历史记忆可能携带看似正常、实际改变任务目标的指令。
- 动作放大效应：模型一旦获得文件、命令、浏览器或外部接口能力，文本层面的误判会转化为越权、外联和数据泄露。
- 供应链不透明：插件、Skill、MCP 工具和脚本带来依赖混淆、恶意下载、隐蔽外联和高危权限调用。
- 过程不可追溯：缺少请求、判定、审批、执行和输出的关联证据，难以定位责任、复现问题和验证修复。

1.3 政企场景约束

- 数据不出域：检测模型和 Judge 应支持本地自托管，云端调用必须显式配置并可关闭。
- 最小权限：高风险工具默认不直接执行，敏感路径、域名和命令需要白名单或人工审批。
- 业务连续性：良性请求误报会直接影响办事效率，因此采用分级处置而非单一硬拦。
- 审计可用：日志需脱敏、可检索、可校验，并能把事件关联回来源和具体动作。

2 总体技术路线

2.1 设计原则

- 旁挂接入：通过 OpenAI 兼容 LLM API、MCP 代理和工具适配器接入，尽量不侵入上游 Agent。
- 策略与检测解耦：检测器只产出 Finding 和证据，策略引擎负责结合来源、动作和链路给出处置。
- 纵深防御：输入、工具、输出三道闸门对称布置，任一层漏判不应直接导致高危动作落地。
- 可复现优先：样例、标注、运行命令和结果文件进入仓库，效果结论附带数据口径和环境。



安全关键路径默认 fail-closed；低风险可用性路径保留审计证据并支持策略化降级

2.2 端到端运行流程

一次请求先由输入闸门标注来源类型和信任级别，并运行多个检测器；模型规划出的工具调用进入归因、风险评分和任务链分析，再由 YAML 策略计算处置。放行动作进入受限执行器，结果回填前经过工具结果检测；模型最终输出再过出口闸门。所有关键节点写入带哈希链的审计事件，评测模式则以相同管线回放固定样例。

2.3 组件与职责

层次	核心模块	职责
core	pipeline / gateway / models	领域模型、管线编排、判定映射和审计事件契约
capabilities	detectors / toolguard / sandbox / supplychain	检测、归因、风险评分、链分析、执行和组件扫描
adapters	FastAPI / assistant / model client / auth	API 接入、助手编排、模型转发、鉴权与存储
console	React + TypeScript	事件、策略、工具、供应链、评测和审计运营
eval	dataset / runner / metrics / report	数据加载、回放、指标聚合和结果输出

2.4 技术栈与部署

后端使用 Python 3.11、FastAPI、Pydantic v2、YAML 配置和 SQLite/内存审计 sink；前端使用 React 18、TypeScript、Vite、TanStack Query、Radix UI 和 Tailwind CSS。部署提供 Dockerfile 与 Docker Compose，容器以非 root 用户运行，默认由单容器同时提供 API、网关和构建后的控制台。

3 算法与安全策略设计

3.1 多源输入检测与风险评估

输入对象统一为带来源元数据的事件：source_type (user、webpage、document、retrieval、memory、tool_return 等)、source_trust、会话和请求标识。规则检测器覆盖注入、越狱、编码/混淆、敏感信息、投毒和外泄信道；可选 ML classifier 或本地 LLM Judge 用于补充语义召回。检测结果以 Finding 表达，包括 kind、score、severity、evidence 和 source。

多检测器结果先做标准化，再按最高风险、来源信任和证据强度聚合。当前网关阈值为 score >= 0.8 进入 block，0.6-0.8 进入 approve，其余允许或净化；策略文件可进一步按来源、路径、域名、动作和任务链覆盖默认判定。阈值本身不是全部算法价值，核心在多源证据和后续动作层约束。

3.2 工具调用治理

步骤	输入	输出与约束
感知	ToolIntent、参数、来源证据	识别文件、命令、网络、数据库等动作类型
风险评分	工具固有风险 + 参数风险	得到 low/medium/high/critical 与可解释原因
链分析	最近工具轨迹、摘要、来源污染	识别敏感读取 -> 外发、工具返回 -> 外发、返回 -> 记忆写入
策略判定	风险、信任、路径、域名、链风险	allow / sanitize / approve / block
执行	受限执行器、超时、资源限制	隔离运行、审计前后快照、异常终止

高危动作不以模型输出为最终依据。文件读取检查敏感路径和工作区 containment；HTTP 请求检查 scheme、解析后的 IP、域名白名单和载荷大小；shell 执行检查危险命令和参数；工具结果回填按 tool_call_id 对齐，避免跨调用混淆。

3.3 分级策略与审批

策略采用声明式 YAML，条件可以引用 source_trust、action、risk、path_matches、domain_allowlist、chain_pattern 和 attribution_confidence。处置等级定义为 allow < sanitize < approve < block。高危写操作通过 HMAC action token 绑定工具、操作者和会话，审批超时默认拒绝；人工放行也会写入审计链。

3.4 供应链检测

组件上线前扫描 manifest、权限声明、依赖关系和外联配置，检测 typosquatting、可疑下载、隐蔽外联、危险权限与已知恶意逻辑。输出组件评级和退出码，恶意组件不得进入运行时注册表。代码级 Semgrep、完整依赖图和行为沙箱属于后续增强，不在当前冻结主结果中宣称已覆盖。

4 审计、溯源与控制台

4.1 证据模型

AuditEvent 覆盖请求接入、检测命中、策略判定、审批、工具执行、模型转发和出口拦截。事件包含 request_id、session_id、principal、action、decision、risk、source、evidence_digest、policy_id、timestamp 和 prev_hash/current_hash。展示层采用白名单字段与脱敏摘要，原始敏感内容不直接写入控制台。

hash-chain 以事件顺序形成链式摘要，可选 HMAC 防止离线篡改。审计 sink 提供内存实现用于测试和演示，SQLite 实现用于持久化；审计写入失败时，高危动作默认阻断并进入本地重试队列。

4.2 来源归因

EvidenceAttributor 将工具参数中的 URL、路径、短文本片段与上游来源内容进行匹配，产生带置信度的归因边。归因结果用于解释“哪个不可信来源驱动了哪个动作”，并作为策略条件。当前归因优先保证可解释和低误报；对跨请求、跨会话的长期污染，需要补充 SessionTraceStore。

4.3 运营控制台

控制台围绕日常运维而非演示装饰设计，提供总览、事件流、网关实测、策略中心、工具调用、供应链、审计、评测、用户权限和备份导入导出等模块。页面优先读取真实后端数据；无数据时显示诚实空态，不用历史 seed 冒充线上结果。

4.4 身份与权限

Principal、角色、组织和团队范围约束控制台操作；高风险操作需要显式权限和二次确认。备份文件导入遵循 schema、大小、路径和内容校验，避免通过导入功能读取工作区外文件。

5 实验方案与复现方法

5.1 实验对象

对象	配置	用途
Baseline	不启用 Fulcrum，恶意样例直接进入被保护 Agent	估计原始攻击成功率
Fulcrum default	生产装配 + data/policies/default.yml	确定性主基线
Fulcrum gov_demo	政务演示策略与域名/工具白名单	验证策略差异
专项 Judge	本地 OpenAI 兼容模型，需单独配置	补充语义召回，并不入主表

5.2 数据集与标注

主数据集为 `samples/eval/corpus` v1.0.0，共 200 条，恶意 170 条、良性 30 条，覆盖 direct_prompt_injection、indirect_injection、jailbreak、knowledge_poisoning、unauthorized_tool、data_leak、data_exfiltration、supply_chain 等类别。每条样例包含 sample_id、source_type、source_trust、ground_truth_malicious、expected_action、risk_level、target_tool、success_condition 和 expected_audit_fields。攻击样例已脱敏，仅用于评测和复现。

链式样例位于 `samples/eval/chains.jsonl`，不并入 200 条主表；原因是主评测保持冻结可比，链分析采用独立命令验证。

5.3 运行步骤

uv sync 安装依赖后，执行 `python -m fulcrum.eval --dataset samples/eval/corpus`。程序输出控制台摘要，并生成 `docs/eval/results/latest.json` 与 Markdown 记分卡。供应链扫描使用 `python -m fulcrum.scan samples/supplychain/<component>`；完整系统可由 `docker compose -f deploy/docker-compose.yml up -d --build` 启动。

5.4 对照与消融

- 关闭输入检测，观察输入闸门对召回和 FPR 的贡献。
- 关闭工具策略，观察越权工具和外泄链的阻断变化。
- 关闭出口检测，验证敏感信息、系统提示和外带信道的残余风险。
- 按攻击类型、来源类型、严重度和防御闸门分桶；所有报告保留逐样例 predicted、expected、held、audit_ok 和 reason。

6 指标体系

6.1 判定定义

对恶意样例，直接 allow 计为攻击成功；sanitize、approve、block 视为已管控。二分类指标把 block、approve、sanitize 归为 held。多级处置准确率则逐条比较 predicted_action 与 expected_action，避免只看“拦没拦”。

指标	定义	方向
ASR	恶意样例被直接放行数 / 恶意样例总数	越低越好
召回率 / BSR	$TP / (TP + FN)$	越高越好
Precision	$TP / (TP + FP)$	越高越好
F1	$2 \times Precision \times Recall / (Precision + Recall)$	越高越好
FPR	$FP / (FP + TN)$	越低越好
Utility	良性任务正确放行数 / 良性任务总数	越高越好
处置准确率	四级动作与 expected_action 一致数 / 总动作数	越高越好
高危动作正确处置率	高危动作被 block 或 approve 的比例	越高越好
审计完整率	关键动作必需字段齐全数 / 关键动作总数	越高越好
溯源 Hit@k	真实来源进入前 k 个归因结果的比例	越高越好
P95 延迟开销	启用网关相对基线的 95 分位净增延迟	越低越好

6.2 主结果（冻结基线）

指标	结果	样本/口径
样例总数	200	恶意 170，良性 30
ASR baseline -> Fulcrum	100.0% -> 10.6%	恶意直接放行 18/170
召回率	89.4%	TP=152, FN=18
Precision / F1	100.0% / 94.4%	FP=0, TN=30
FPR / Utility	0.0% / 100.0%	良性 30 条
处置准确率	73.5%	四级 expected_action
高危动作处置率	85.9%	高危样例子集
供应链恶意组件召回	90.9%	11 条 supply_chain
来源 Hit@1 / Hit@3	100.0% / 100.0%	29 条带金标准来源
审计 / hash-chain	100.0% / 100.0%	关键动作全量
P95 净增延迟	1.439 ms	网关侧，未含远端模型耗时

结果来源：`docs/eval/results/latest.json`，数据集 `samples/eval/corpus`，由 `python -m fulcrum.eval --dataset samples/eval/corpus` 生成。该文件未记录独立生成时间字段，报告不将其解释为当前远端开发分支的最新成绩。

6.3 开发分支记录的口径边界

仓库部分规划与评审记录提到后续开发分支曾达到约 98.2% 召回和 92.0% 处置准确率，但这些数字不在本报告采用的 `latest.json` 主结果文件中，且对应的代码基线、数据版本和运行时间不完整。为保证可审计性，本报告不将其作为已验证成绩；待分支合并、语料和命令统一后再生成独立对照表。

7 结果解释、预期效果与边界

7.1 分域结果

防御闸门	样例	恶意	召回/管控	处置准确率
输入 screen_input	106	89	80.9%	55.7%
工具 evaluate_intent	67	61	100.0%	98.5%
输出 screen_output	27	20	95.0%	81.5%

工具治理和出口检测在冻结结果中表现较强，输入闸门仍是主要短板，尤其是无明显触发词的语义注入、编码嵌套和间接污染。该分域结果直接指导后续研发：优先提高输入语义召回，同时保持硬负例 FPR 不上升。

7.2 预期效果（按验收口径）

- 安全性：在冻结样例上维持 FPR 0%，降低恶意直接放行；高危工具默认阻断或转审批。
- 可用性：良性任务 Utility 维持 100% 的基线表现，采用 sanitize/approve 降低误伤成本。
- 可审计性：关键事件字段完整，hash-chain 可校验，支持按请求、会话、操作者和策略追溯。
- 可运维性：策略 YAML 外置，评测结果自动生成，检测器可插拔，支持私有化和离线部署。
- 可扩展性：通过 MCP、OpenAI 兼容 API 和非 MCP 工具适配器覆盖不同 Agent 框架。

7.3 已知边界与风险

- 冻结 200 条语料不能代表全部真实流量；样例分布和标注协议会显著影响指标。
- 规则和小模型对新型语义攻击、跨请求链和跨会话记忆污染仍可能漏判。
- 受限子进程的网络限制不是完整网络命名空间；非 Python 原生程序和恶意原生代码需容器或更强隔离。
- 网关无法防止部署侧绕过代理；生产部署必须限制 Agent 直连模型和工具的网络出口。
- LLM Judge 会增加延迟和资源消耗，必须使用本地模型、超时、熔断和只升格不降格原则。

7.4 后续验证计划

在保持 v1.0.0 冻结的前提下，新增 held-out benign、跨模型和跨强度实验；完善 SessionTraceStore、工具能力元数据和容器级沙箱；对新检测器统一 rebase 到最新开发基线后再评测，避免历史分支结果与主表混用。

8 实施计划与交付

阶段	主要工作	验收证据
阶段一：基线固化	冻结样例、策略、运行环境和指标脚本	latest.json、版本号、复现命令
阶段二：核心防护	输入/工具/输出三闸门，来源归因和策略外置	逐样例结果、工具阻断记录、审计链
阶段三：运营闭环	控制台、RBAC、SQLite 审计、供应链准入	页面接口、权限测试、组件扫描报告
阶段四：增强验证	本地 Judge、跨模型、跨会话链分析、容器沙箱	专项报告、消融表、held-out 结果
阶段五：场景对接	政务办公、知识问答、流程办理、运维协同试点	脱敏演示、部署手册、风险清单

交付物包括：本 PDF 技术方案报告；Fulcrum 原型代码仓库；`samples/eval/corpus` 脱敏样例与 SPEC；评测脚本和结果 JSON；Docker 部署文件；控制台和审计日志示例。演示视频按十分钟以内组织，依次展示正常请求、输入阻断、工具审批/沙箱、出口拦截、审计追溯和评测复现。

附录 A 关键目录与入口

路径	说明
src/fulcrum/core	领域模型、管线、网关、策略契约
src/fulcrum/capabilities	检测器、归因、工具治理、沙箱、供应链
src/fulcrum/adapters	FastAPI、助手、模型客户端、鉴权、审计存储
samples/eval/corpus	v1.0.0 冻结评测语料与标注规范
docs/eval/results/latest.json	主评测逐样例结果与聚合指标
data/policies/*.yaml	默认和政务演示策略
deploy/docker-compose.yaml	一键部署入口

附录 B 术语

ASR：攻击成功率；BSR：阻断成功率；FPR：良性样例误报率；HITL：人在环审批；SSRF：服务端请求伪造；MCP：模型上下文协议；LOLBins：可被滥用的系统原生工具；hash-chain：按前一事件摘要串联的防篡改证据链。

修订记录

版本	日期	变更
v1.0	2026-08-31	依据赛题 XA-202620、当前代码架构和冻结评测结果重编；明确历史/专项数据边界，补充实验复现、风险边界和交付计划。